



HackSimulator.nl

```
user@hacksimulator:~$
```

Ethisch Hacken & de Nederlandse Wet

Wat Mag Wel, Wat Mag Niet? — Een praktische gids voor (aankomende) ethische hackers in Nederland

Versie 1.0 · april 2026

Over deze gids

Je wilt ethisch hacken leren. Misschien heb je al wat commands uitgeprobeerd in HackSimulator, of je bent net begonnen met je eerste Nmap scan. En dan komt de vraag: *mag dit eigenlijk wel?*

Het korte antwoord: **hacken is niet per definitie illegaal — ongeautoriseerd hacken is dat wél**. Het verschil zit in toestemming, proportionaliteit en hoe je ermee omgaat.

Deze gids legt in gewoon Nederlands uit wat de wet zegt, wat je wél mag doen, en hoe je jezelf beschermt. Geen juridisch jargon, geen vage disclaimers — concrete regels en echte voorbeelden.

[LET OP] Deze gids is informatief en vervangt geen juridisch advies. Bij twijfel: raadpleeg een advocaat gespecialiseerd in cybercrime.

De Wet — Wat Zegt de Nederlandse Wet Over Hacken?

Artikel 138ab Sr — Computervredebreuk

De kern van de Nederlandse hackwetgeving is **artikel 138ab van het Wetboek van Strafrecht**. Dit artikel stelt “computervredebreuk” strafbaar: het opzettelijk en wederrechtelijk binnendringen in een geautomatiseerd werk (computer, server, netwerk, database, IoT-apparaat — elk digitaal systeem).

De drie leden van art. 138ab Sr

Lid	Wat is strafbaar?	Maximale straf
Lid 1 — Basis	Opzettelijk en wederrechtelijk binnendringen in een geautomatiseerd werk	2 jaar cel of geldboete vierde categorie (max. €27.500 per 2026)
Lid 2 — Met datadiefstal	Binnendringen + vervolgens gegevens overnemen, aftappen of opnemen	4 jaar cel of geldboete vierde categorie
Lid 3 — Via telecom-netwerk	Binnendringen via openbaar telecom-netwerk + verwerkingscapaciteit misbruiken of als springplank naar andere systemen	4 jaar cel of geldboete vierde categorie

Wat telt als “binnendringen”? De wet noemt expliciet:

- Doorbreken van een beveiliging (wachtwoord kraken, firewall omzeilen)
- Technische ingreep (exploit gebruiken, buffer overflow)
- Valse signalen of een valse sleutel (gestolen credentials, session hijacking)
- Aannemen van een valse hoedanigheid (social engineering, phishing)

[!] Sinds de Wet Computercriminaliteit III (2019) hoeft er **geen beveiliging doorbroken** te zijn. Ook een onbeveiligd systeem binnendringen zonder toestemming is strafbaar.

Bron: [Art. 138ab Wetboek van Strafrecht](#) — inwerkingtreding 20 april 2016, gewijzigd bij Wet Computercriminaliteit III (2019)

Andere relevante artikelen

Artikel	Wat	Straf
Art. 138b Sr	DDoS-aanvallen (opzettelijk ontoegankelijk maken van geautomatiseerd werk)	2-5 jaar cel
Art. 139c Sr	Aftappen of opnemen van communicatie (bijv. packet sniffing zonder toestemming)	2 jaar cel
Art. 139d Sr	Plaatsen van af luisterapparatuur of spyware	2-4 jaar cel

Art. 350a Sr	Opzettelijk beschadigen/onbruikbaar maken van computergegevens	2-4 jaar cel
Art. 350b Sr	Nalatige verspreiding van malware	1 maand hechtenis of geldboete

De Drie Wetten Computercriminaliteit

Nederland heeft drie belangrijke wetten op het gebied van computercriminaliteit aangenomen:

Wet	Jaar	Wat veranderde?
Wet Computercriminaliteit I	1993	Eerste keer dat computervredebreuk strafbaar werd gesteld
Wet Computercriminaliteit II	2006	Uitbreiding naar DDoS, malware, voorbereidingshandelingen
Wet Computercriminaliteit III	2019	Politie mag zelf terughacken. Geen beveiligingseis meer nodig. Strafverzwaring bij vitale infra

Wet Computercriminaliteit III is de meest ingrijpende: de politie en het OM kregen hiermee de bevoegdheid om zelf in te breken in verdachte systemen ("terughackbevoegdheid"). Voor jou als ethische hacker veranderde vooral dit: **ook onbeveiligde systemen binnendringen is nu strafbaar.**

Wat Mag Wél — Wanneer is Hacken Niet Strafbaar?

De Gouden Regel: Toestemming

De eenvoudigste manier om legaal te hacken: **vraag toestemming**. Schriftelijk. Vooraf. Concreet.

Situatie	Legaal?	Waarom?
Je werkgever vraagt je hun systeem te testen	Ja	Schriftelijke opdracht = toestemming
Je scant je eigen thuisnetwerk met Nmap	Ja	Eigen systeem = eigen toestemming
Je scant het wifi-netwerk van je buurman “uit nieuwsgierigheid”	Nee	Geen toestemming, geen reden
Je vindt per ongeluk een open database en downloadt alles	Nee	Geen toestemming + disproportioneel
Bug bounty programma van een bedrijf	Ja	Bug bounty = expliciete uitnodiging

Coordinated Vulnerability Disclosure (CVD)

Wat als je per toeval een kwetsbaarheid vindt? Nederland heeft hiervoor een internationaal geprezen systeem: **Coordinated Vulnerability Disclosure** (CVD), voorheen “Responsible Disclosure” genoemd.

Zo werkt CVD:

1. Je vindt een kwetsbaarheid
2. Je meldt het **direct** aan de eigenaar van het systeem (of aan het NCSC)
3. Je houdt de kwetsbaarheid **geheim** totdat deze is opgelost
4. Je gaat **niet verder dan nodig** om het probleem aan te tonen
5. De eigenaar lost het op, en je krijgt (eventueel) erkenning

NCSC-tijdslijnen bij melding:

Stap	Termijn
Bevestiging ontvangst	1 werkdag
Eerste beoordeling	3 werkdagen
Oplossing door organisatie	Richt op 60 dagen

Wat je NIET mag doen bij CVD:

- Malware plaatsen
- Gegevens kopiëren of downloaden (meer dan strikt nodig als bewijs)
- Brute force aanvallen uitvoeren
- DDoS-aanvallen uitvoeren
- Social engineering toepassen
- Wijzigingen aanbrengen in het systeem

De Drie Juridische Voorwaarden

Het Openbaar Ministerie (OM) erkent dat ethisch hacken onder bepaalde omstandigheden niet wettelijk is. Maar je moet aan **drie voorwaarden** voldoen:

1. Zwaarwegend maatschappelijk belang

Je hack moet een echt maatschappelijk doel dienen — niet je nieuwsgierigheid bevredigen of indruk maken op vrienden.

2. Proportionaliteit

Je mag niet verder gaan dan nodig om de kwetsbaarheid aan te tonen. Eén bestand downloaden als bewijs? Mogelijk acceptabel. Een hele database kopiëren? Nooit.

3. Subsidiariteit

Was er een minder ingrijpende manier om hetzelfde doel te bereiken? Had je het bedrijf eerst kunnen mailen? Dan had je dat moeten doen.

[LET OP] Zelfs als je aan alle drie voorwaarden voldoet, biedt dit **geen garantie** op strafrechtelijke immunitet. Het OM kan altijd besluiten om te vervolgen. CVD is een richtlijn, geen vrijbrief.

Echte Rechtszaken — Wat Ging Er Mis?

Zaak 1: De zorginstelling-hack (2013)

Wat gebeurde er? Een journalist en politicus wilde aantonen dat een zorginstelling slechte beveiliging had. Hij logde met de inloggegevens van een patiënt in op het systeem en bekeek en printte meerdere (echte) medische dossiers als bewijs.

Het vonnis: €750 boete — schuldig aan computervredebreuk.

Waarom? De rechter oordeelde dat het inzien en kopiëren van meerdere dossiers **disproportioneel** was. Eén dossier had als bewijs volstaan. De intentie was goed — de rechter prees zelfs de zorgvuldigheid waarmee het lek in kaart werd gebracht — maar de uitvoering ging te ver.

[TIP] Proportionaliteit is alles. Bewijs dat er een lek is, kopieer niet meer dan strikt noodzakelijk.

Bron: [ECLI:NL:RBOBR:2013:BZ1157](#) — Rechtbank Oost-Brabant, 2013.

Zaak 2: Te ver doorzoeken na binnenkomst

Het patroon: Iemand verschaft zich toegang tot een (zorg)systeem en blijft daarna herhaaldelijk inloggen en door gevoelige gegevens zoeken — veel verder dan nodig is om een lek aan te tonen.

De lijn in de rechtspraak: Dit levert een veroordeling voor computervredebreuk op. Herhaaldelijk inloggen en rondzoeken overschrijdt elke redelijke grens van “kwetsbaarheid aantonen” — precies de proportionaliteitsgrens die ook in Zaak 1 de doorslag gaf.

[TIP] Eén keer binnenkomen om een lek te bewijzen is niet hetzelfde als rondneuzen in andermans data.

Zaak 3: Grootschalige datadiefstal (Rechtbank Gelderland)

Wat gebeurde er? Een 27-jarige man had toegang verkregen tot meer dan 3,7 miljoen inloggegevens van webshops.

Het vonnis: 27 maanden gevangenisstraf + €10.000 boete.

[!] Schaal maakt het verschil. Dit is geen ethisch hacken — dit is datadiefstal.

Bron: [Rechtbank Gelderland, april 2021 — Rechtspraak.nl](#)

De AVG/GDPR en Pentesting

Als je penetration tests uitvoert — zelfs met toestemming — loop je kans om met persoonsgegevens in aanraking te komen. De Algemene Verordening Gegevensbescherming (AVG, internationaal: GDPR) is dan relevant.

Wanneer heb je een verwerkersovereenkomst nodig?

Situatie	Nodig?
Pentest waarbij je mogelijk persoonsgegevens ziet	Ja, in principe
Pentest puur op infrastructuur (firewalls, open poorten)	Nee, waarschijnlijk niet
Bug bounty waar je een SQL injection aantoon	Hangt af van wat je ziet/downloadt

Afspraken die je ALTIJD moet maken

Bij elke professionele pentest moet je het volgende regelen:

- **Geheimhouding:** Alles wat je ziet is vertrouwelijk
- **Dataminimalisatie:** Kopieer zo min mogelijk gegevens
- **Vernietiging:** Vernietig alle gevonden data na afloop
- **Logging:** Houd bij wat je hebt gedaan (voor je eigen bescherming)
- **Toestemmingsdocument:** Schriftelijke scope-afpraak (welke systemen, welke periode, welke technieken)

Het toestemmingsdocument — Wat moet erin?

Een goed pentest-toestemmingsdocument bevat minimaal:

1. **Wie:** Naam opdrachtgever + naam tester
2. **Wat:** Welke systemen mogen getest worden (scope)
3. **Wanneer:** Start- en einddatum van de test
4. **Hoe:** Welke technieken zijn toegestaan (en welke expliciet NIET)
5. **Communicatie:** Aan wie meld je bevindingen? Hoe snel?
6. **Data:** Wat doe je met gevonden (persoons)gegevens?
7. **Aansprakelijkheid:** Wie is verantwoordelijk bij onbedoelde schade?

[TIP] Zonder dit document op papier heb je geen bewijs van toestemming. “Ze zeiden dat het mocht” is niet genoeg.

Bug Bounty Programma's in Nederland

Bug bounty programma's zijn de veiligste manier om ethisch hacken te oefenen op echte systemen. Je krijgt expliciete toestemming, duidelijke scope, en soms zelfs een beloning.

Wat is een bug bounty programma?

Een organisatie nodigt hackers uit om kwetsbaarheden te vinden in hun systemen. In ruil krijg je:

- Erkenning (Hall of Fame)
- Soms een financiële beloning
- Juridische bescherming (binnen de scope)

Nederlandse organisaties met CVD/bug bounty beleid

Organisatie	Platform	Type
Rijksoverheid	HackerOne	CVD (geen financiële beloning, wel erkenning)
NCSC	Eigen formulier	CVD + Wall of Fame + merchandise
Diverse gemeentes	Zerocopter / HackerOne	CVD

[LET OP] Bug bounty programma's veranderen regelmatig. Check altijd de actuele lijst op het betreffende platform voordat je begint.

Internationale platforms met Nederlandse deelname

- **HackerOne** (hackerone.com) — Grootste platform, veel Nederlandse bedrijven
- **Bugcrowd** (bugcrowd.com) — Alternatief platform
- **Zerocopter** (zerocopter.com) — Nederlands platform, gericht op Nederlandse markt
- **Intigriti** (intigriti.com) — Europees platform (Belgisch, HQ Antwerpen)

Tips voor je eerste bug bounty

1. **Begin met programma's die expliciet beginners verwelkomen** — zoek naar "beginner friendly" tags
2. **Lees de scope grondig** — test alleen wat is toegestaan
3. **Documenteer alles** — screenshots, timestamps, stappen om te reproduceren
4. **Meld netjes** — gebruik het format van het platform
5. **Wees geduldig** — reactietijden variëren van dagen tot weken

Hack_Right — Het OM-programma voor Jonge Hackers

Wat is Hack_Right?

Hack_Right is een programma van het Openbaar Ministerie (OM) en de Politie, specifiek voor jonge hackers (12-30 jaar) die een cyberdelict hebben gepleegd. Het biedt een alternatief voor of aanvulling op strafrechtelijke vervolging.

Voor wie?

- Leeftijd: 12 tot 30 jaar
- Eerste cyberdelict (first offender)
- De verdachte bekent het feit
- Bereid om zich positief te ontwikkelen

De vier modules

Module	Inhoud
1. Juridisch & ethisch	Wetgeving, regels en ethische grenzen
2. Impact & herstel	Bewustwording van schade, excuses, schadeherstel
3. Talentontwikkeling	Digitale vaardigheden positief inzetten (bijv. ethisch hacken)
4. Digitale weerbaarheid	Zelfbescherming en verantwoord gedrag online

Waarom is dit relevant voor jou?

Hack_Right laat zien dat Nederland erkent dat jonge hackers **talent** hebben dat beter benut kan worden. Maar het bestaat alleen omdat er eerst een strafbaar feit is gepleegd. Het doel van deze gids is dat je Hack_Right **nooit nodig hebt** — door vanaf het begin de juiste keuzes te maken.

Bron: [Openbaar Ministerie — Hack_Right](#)

Praktische Checklist — Voordat Je Begint

De 10-Punten Veiligheidscheck

Voordat je enige vorm van security testing uitvoert, loop deze checklist door:

1. **Heb ik schriftelijke toestemming?** (Opdracht, bug bounty scope, of eigen systeem)
2. **Is de scope duidelijk?** (Welke systemen, welke technieken, welke periode)
3. **Weet ik wie ik moet contacteren bij problemen?** (Contactpersoon opdrachtgever)
4. **Log ik al mijn activiteiten?** (Timestamps, commando's, screenshots)
5. **Ga ik niet verder dan nodig?** (Proportionaliteit — bewijs het probleem, kopieer niet alles)
6. **Heb ik afspraken over gevonden data?** (Geheimhouding, vernietiging)
7. **Gebruik ik mijn eigen systeem?** (Niet hacken via het werk-netwerk van een ander)
8. **Ken ik de exit-strategie?** (Wat doe ik als ik per ongeluk iets kapotmaak?)
9. **Heb ik het CVD-beleid gelezen?** (Als je meldt: volg de regels van de organisatie)
10. **Twijfel ik?** (Bij twijfel: **stop en vraag advies**. Liever te voorzichtig dan te laat.)

Samenvatting: De Kernregels

Regel	Details
Toestemming is verplicht	Schriftelijk, vooraf, concreet
Proportionaliteit	Niet meer doen dan nodig om het probleem te bewijzen
Direct melden	Kwetsbaarheden rapporteren, niet zelf exploiteren
Geheimhouding	Niet publiek maken voordat het is opgelost
Documenteren	Log alles — het beschermt jou
Bij twijfel: niet doen	Het risico is niet de moeite waard

Bronnen & Verder Lezen

- [Art. 138ab Wetboek van Strafrecht](#)
- [NCSC — Kwetsbaarheid melden \(CVD\)](#)
- [NCSC — CVD Leidraad \(PDF\)](#)
- [Openbaar Ministerie — Hack_Right](#)
- [Rijksoverheid — Responsible Disclosure](#)
- [Rijksoverheid — Boetecategorieën](#)

*Deze gids is geschreven voor HackSimulator.nl — de gratis browser-based terminal simulator voor ethisch hacken.
Versie 1.0 · Met zorg samengesteld en gecontroleerd · april 2026*